

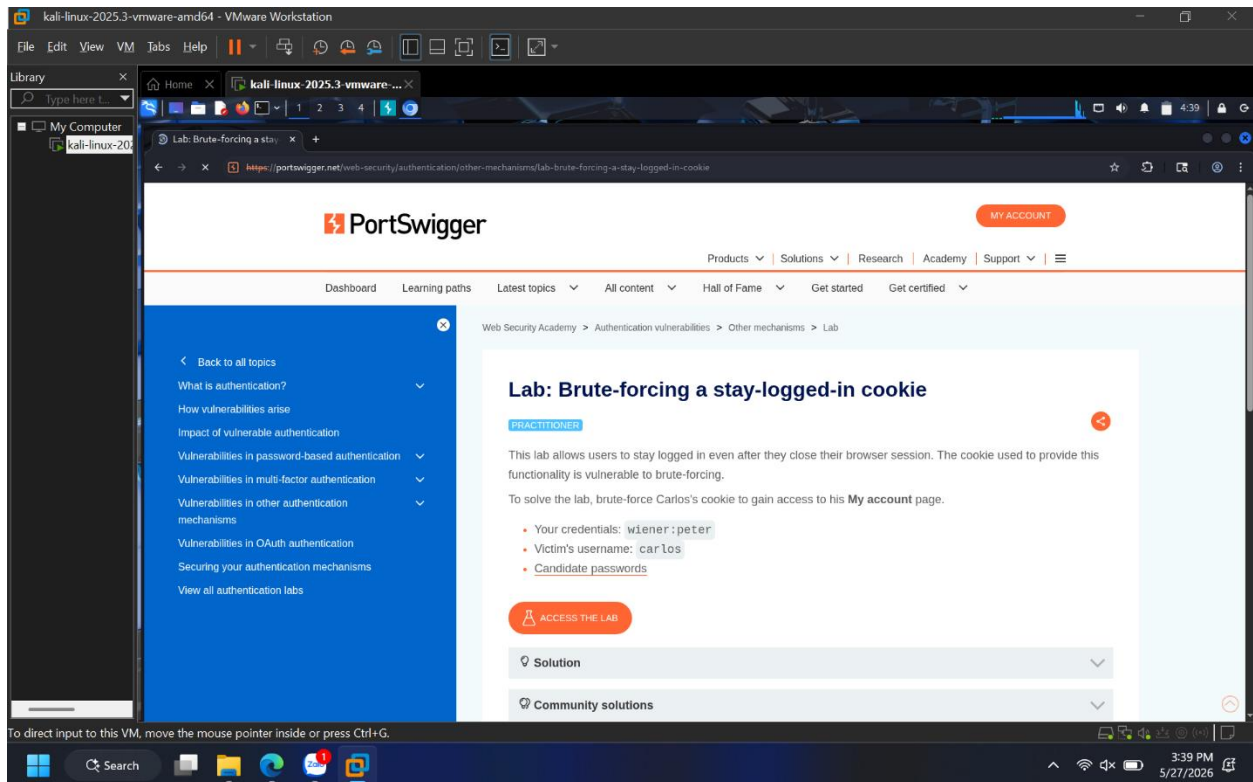
Lab: Brute-forcing a stay-logged-in cookie

1. Mục tiêu của bài lab

-Mục tiêu của bài lab là khai thác lỗ hổng trong chức năng “Stay logged in” bằng cách brute-force cookie đăng nhập của người dùng Carlos để truy cập trái phép vào tài khoản của nạn nhân.

2. Chi tiết bài lab

Bước 1. Mở Burp trên Kali, sau đó thêm URL của lab vào

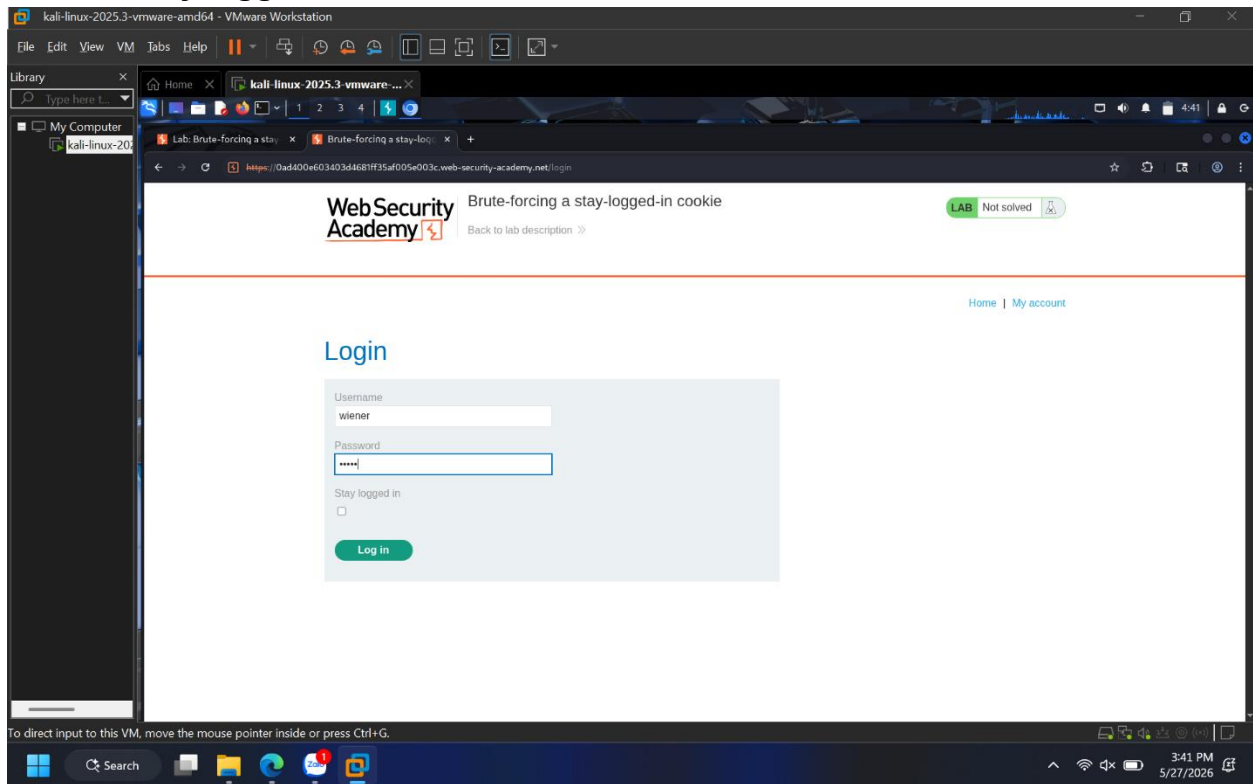


Bước 2: Đăng nhập tài khoản hợp lệ

Username: wiener

Password: peter

Tick vào **stay logged in**



Bước 3: Kiểm tra trong HTTP history

-stay-logged-

in=d2IlbmVyOjUxZGMzMGRkYzQ3M2Q0M2E2MDExZTIiYmJhNmNhNzcx

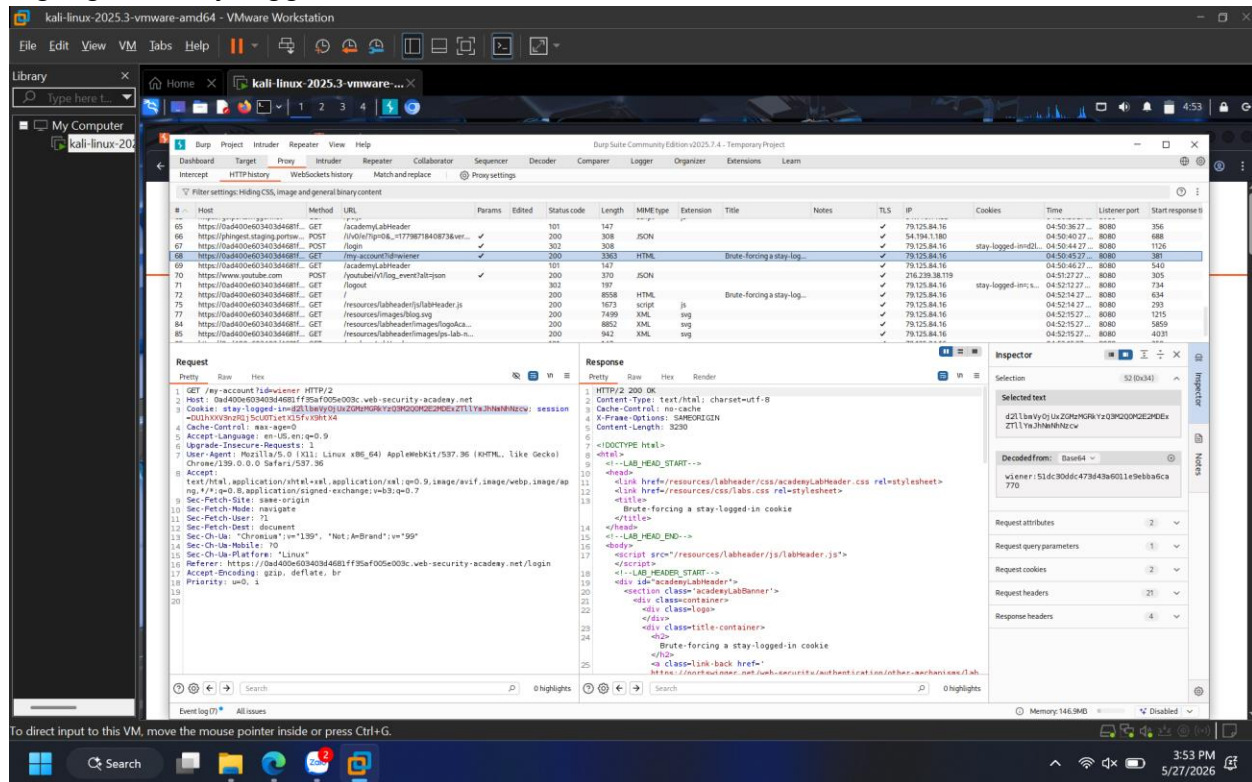
-wiener:51dc30ddc473d43a6011e9ebba6ca770

The screenshot shows a Kali Linux virtual machine running Burp Suite. The main window displays a list of HTTP requests and responses. A request to `https://0ad400e603403468ff35af005e003c.web-security-academy.net/my-account?id=wiener` is selected, showing a 200 status code and a JSON response. The response body contains a `stay-logged-in` cookie with a value that is partially obscured by a red box. The VM's taskbar and desktop icons are visible at the bottom.

Bước 4:Logout tài khoản

The screenshot shows a Kali Linux virtual machine with a web browser open to the Web Security Academy 'My Account' page. The page displays the username 'wiener' and a form to update the email. The browser's address bar shows the URL `https://0ad400e603403468ff35af005e003c.web-security-academy.net/my-account?id=wiener`. The VM's taskbar and desktop icons are visible at the bottom.

Bước 5: Vào lại HTTP history, thấy được **GET /my-account?id=wiener** và phần highlight là stay-logged-in

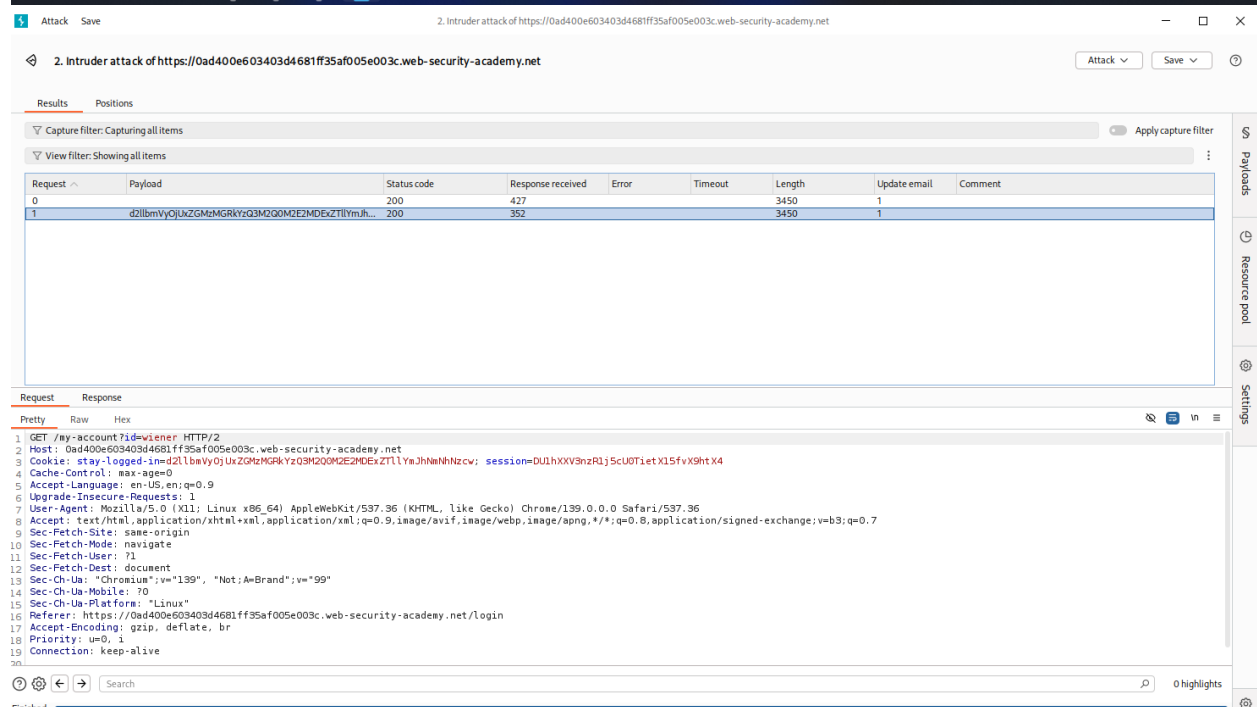
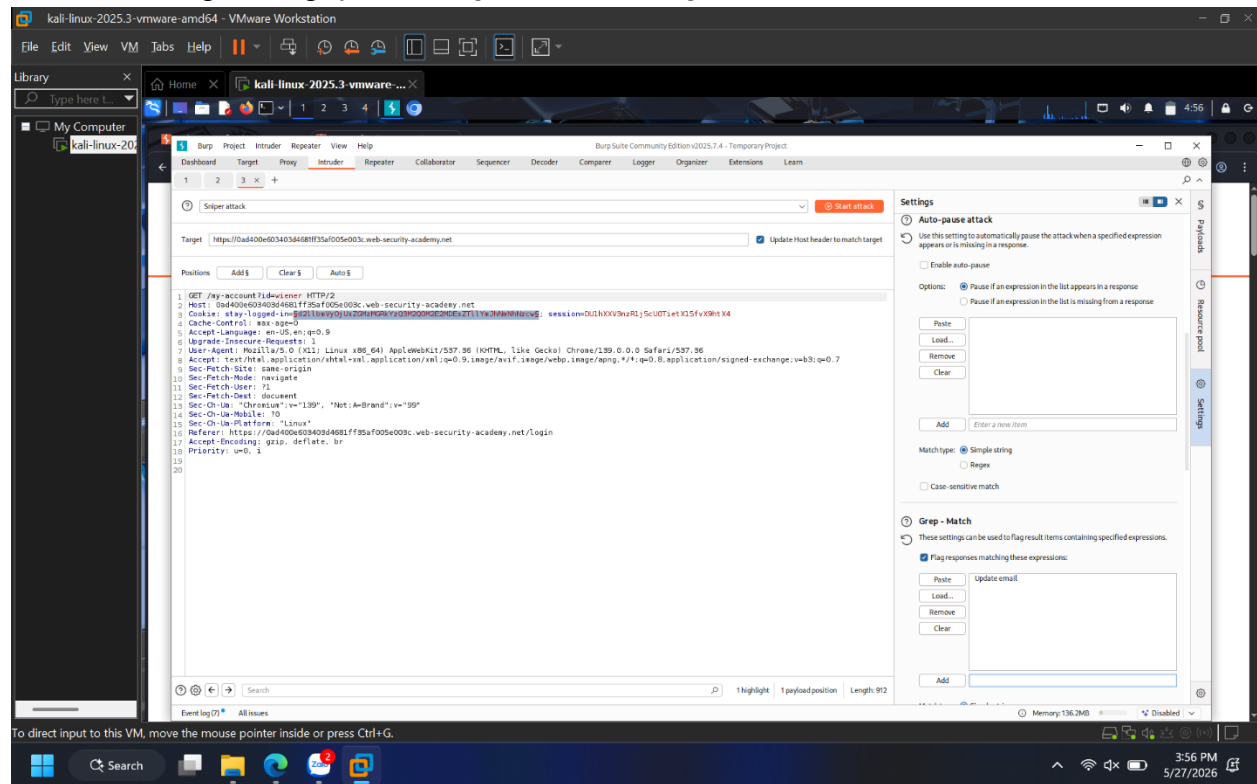


Bước 6: Chuyển phần **stay-logged-in** sang **Intruder**

- Add sẵn phần sau của stay-logged-in
- Phayload configuration add: peter
- Phần payload processing ta add:
Hash: MD5

Add prefix: wiener:

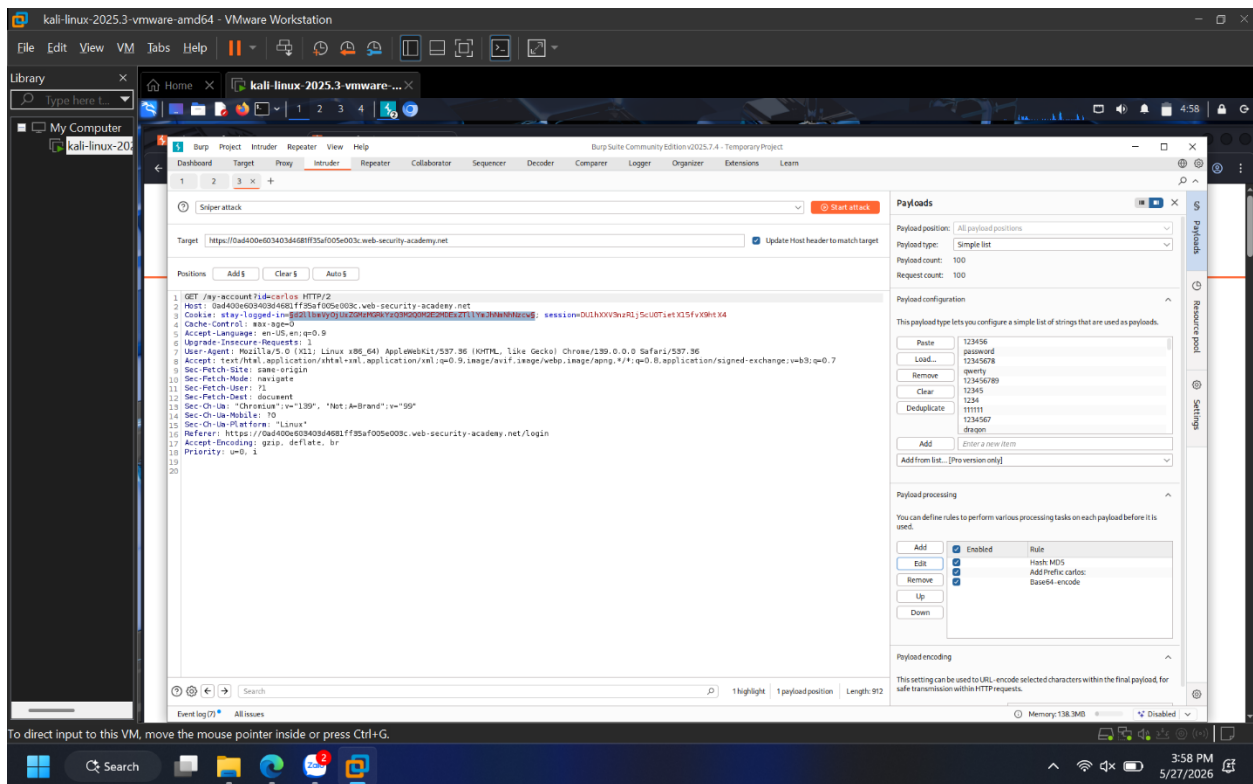
Bước 7: Trong setting, phần **Grep-Match** add update email



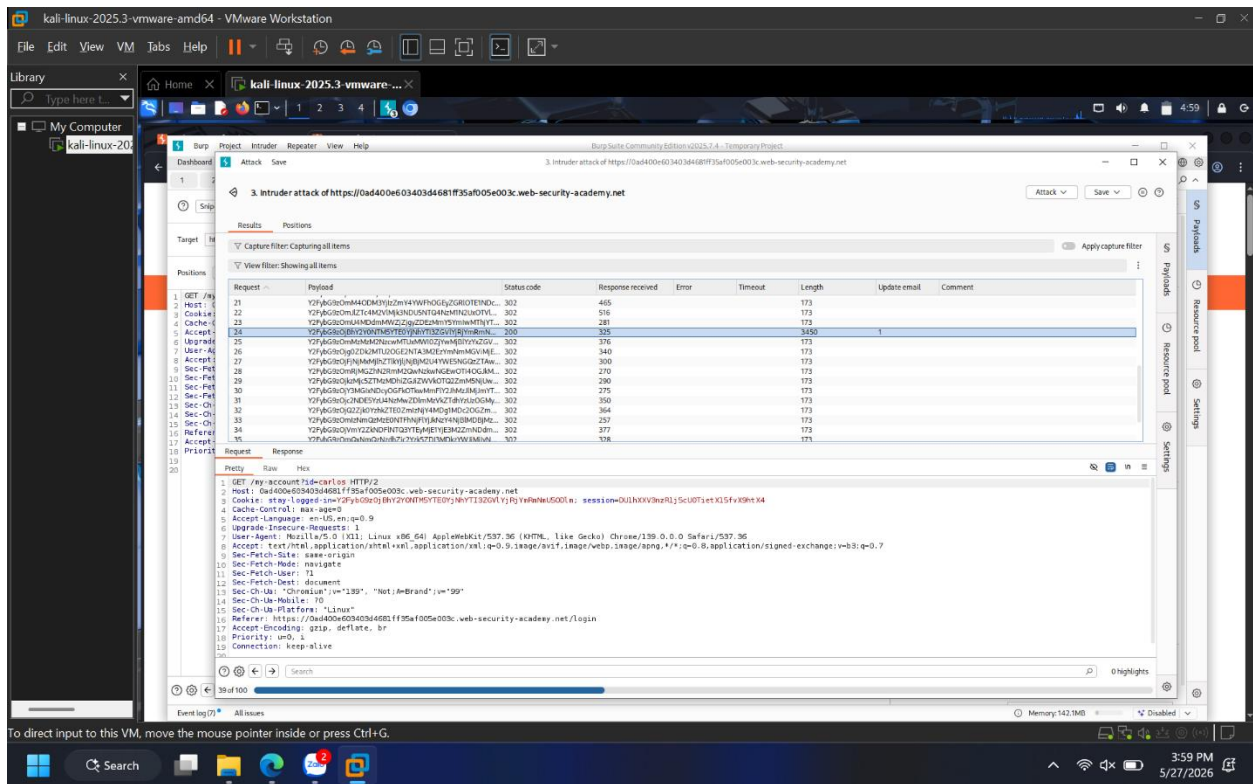
Bước 8: Thay **get/my-account** thành carlos

-Phần payload processing **edit** phần 2 từ wiener sang carlos:

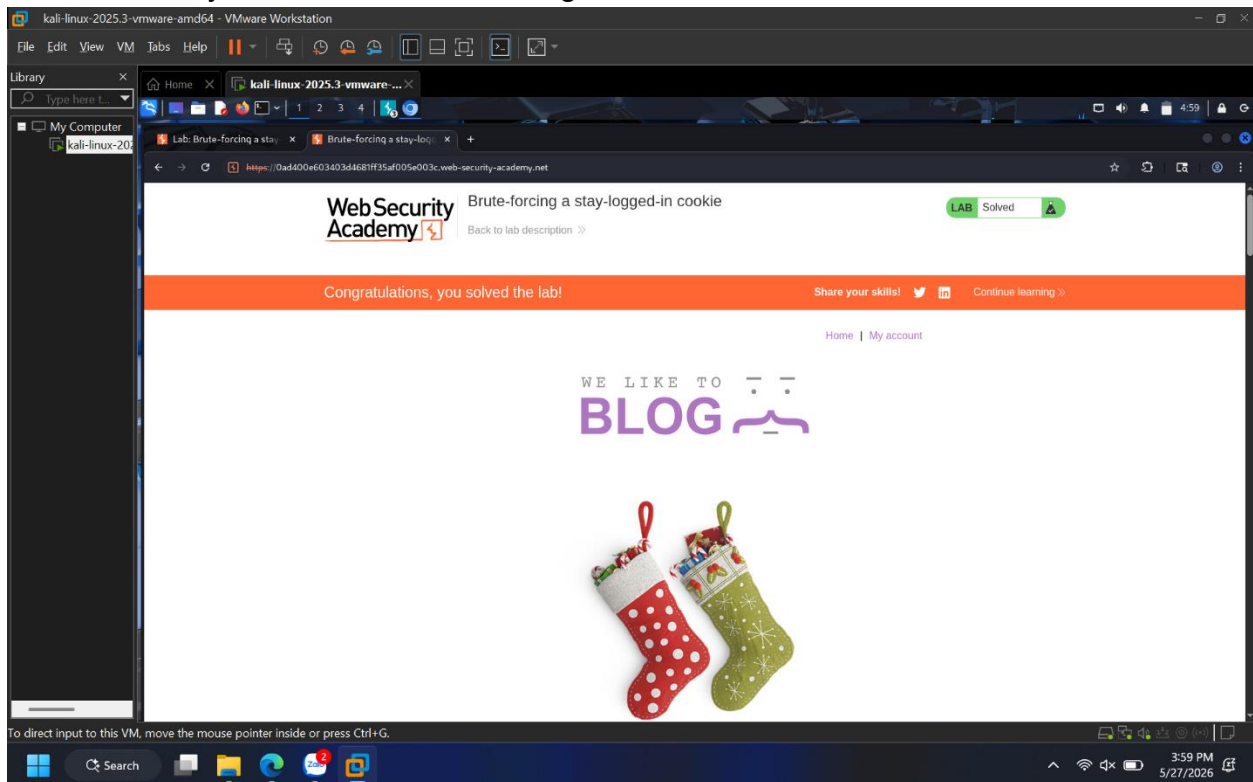
-**Add** thêm password mà đề bài đã cho



Bước 10: Start Attack
phần update email ra = 1



Bước 11: Quay lại lab và lab thành công



Lab: Offline password cracking

1. Mục tiêu của bài lab

-Mục tiêu của bài lab là khai thác lỗ hổng Stored Cross-Site Scripting (Stored XSS) để đánh cắp cookie “stay-logged-in” của người dùng Carlos, sau đó phân tích cookie để tìm mật khẩu và chiếm quyền truy cập tài khoản nạn nhân.

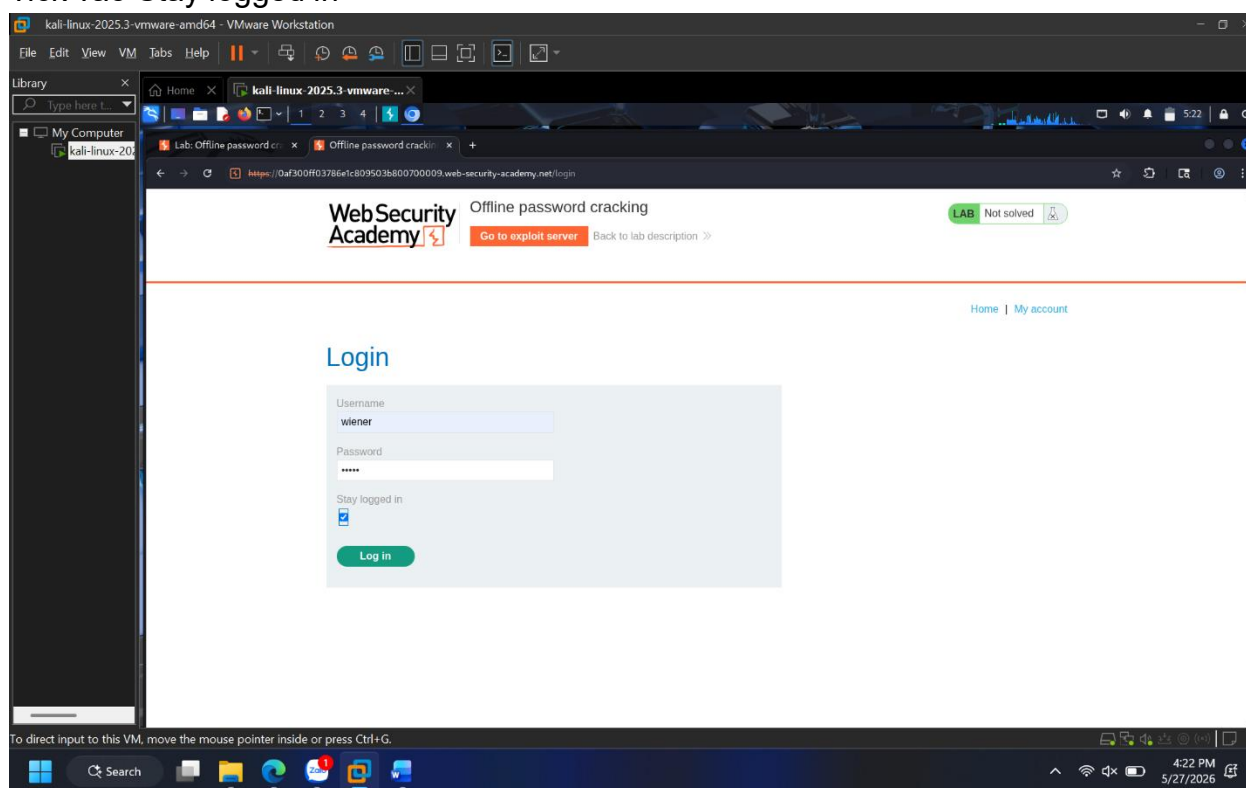
2. Chi tiết lab

Bước 1: Đăng nhập tài khoản hợp lệ

Username: wiener

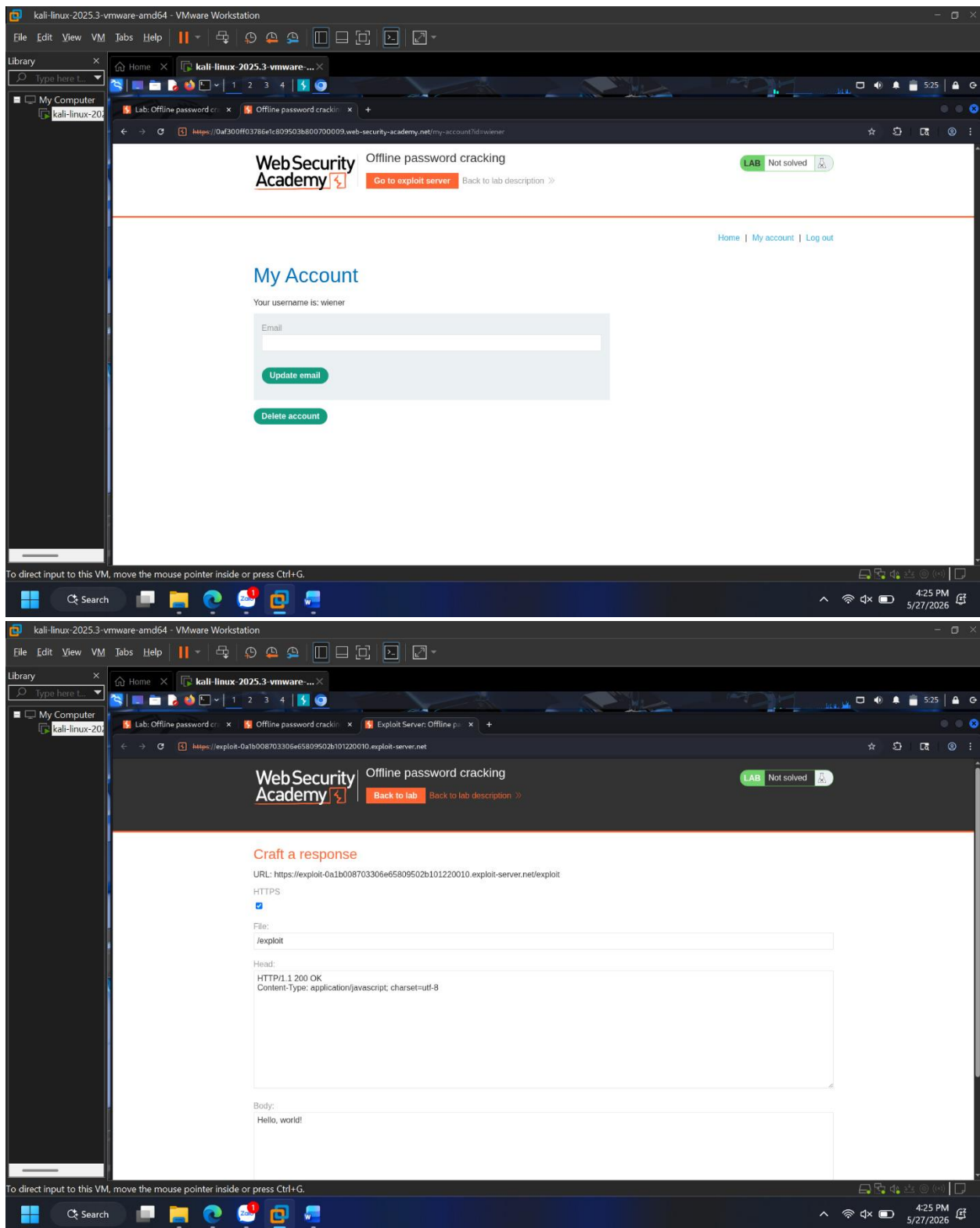
Password: peter

Tick vào Stay logged in

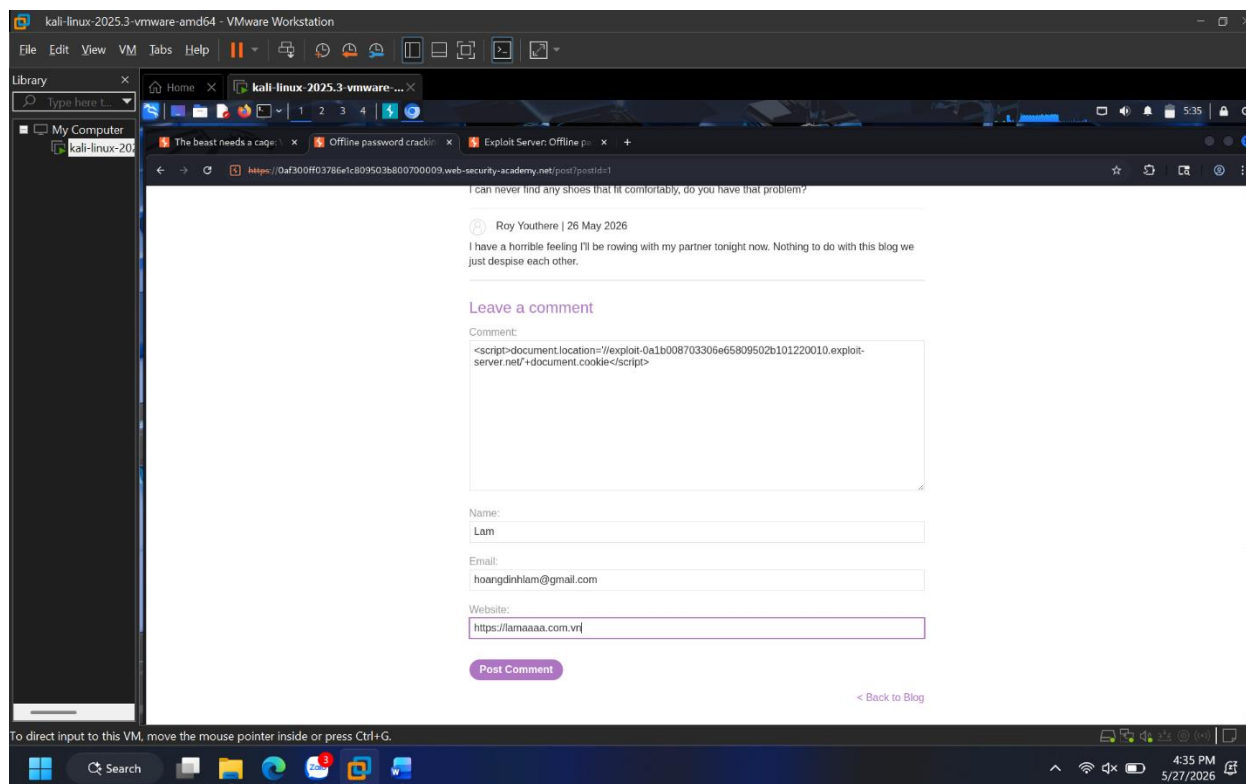


Bước 3: Phân tích **cookies**

stay-logged-in=d2llbmVyOjUxZGMzMGRkYzQ3M2Q0M2E2MDExZTIiYmJhNmNhNzcx

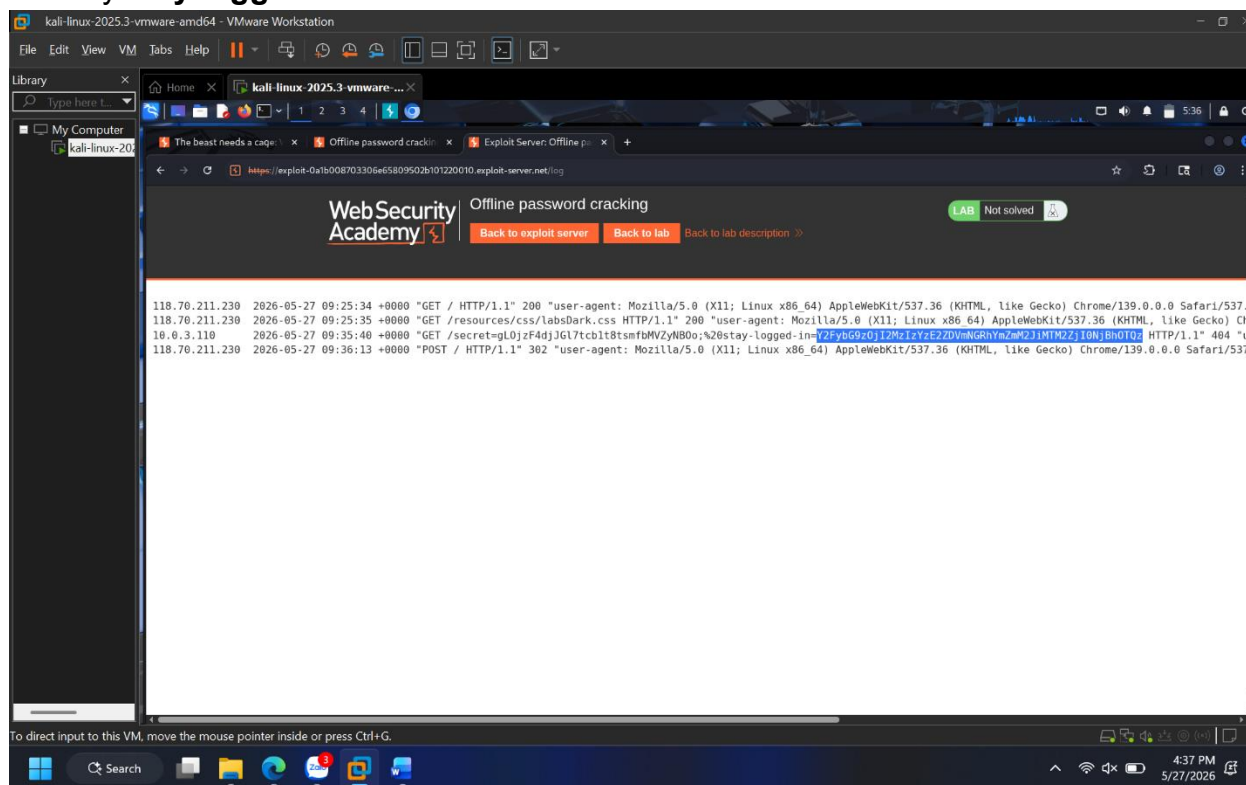


Bước 5: Vào 1 **view post** bất kì, kéo xuống phần **comment** r thêm cái your id của mình vào
Sau đó thêm các bước mà nó yêu cầu



Bước 6: Sau khi chạy xong, quay lại **exploit server**, bấm **access log**

Sẽ thấy **stay-logged-in**

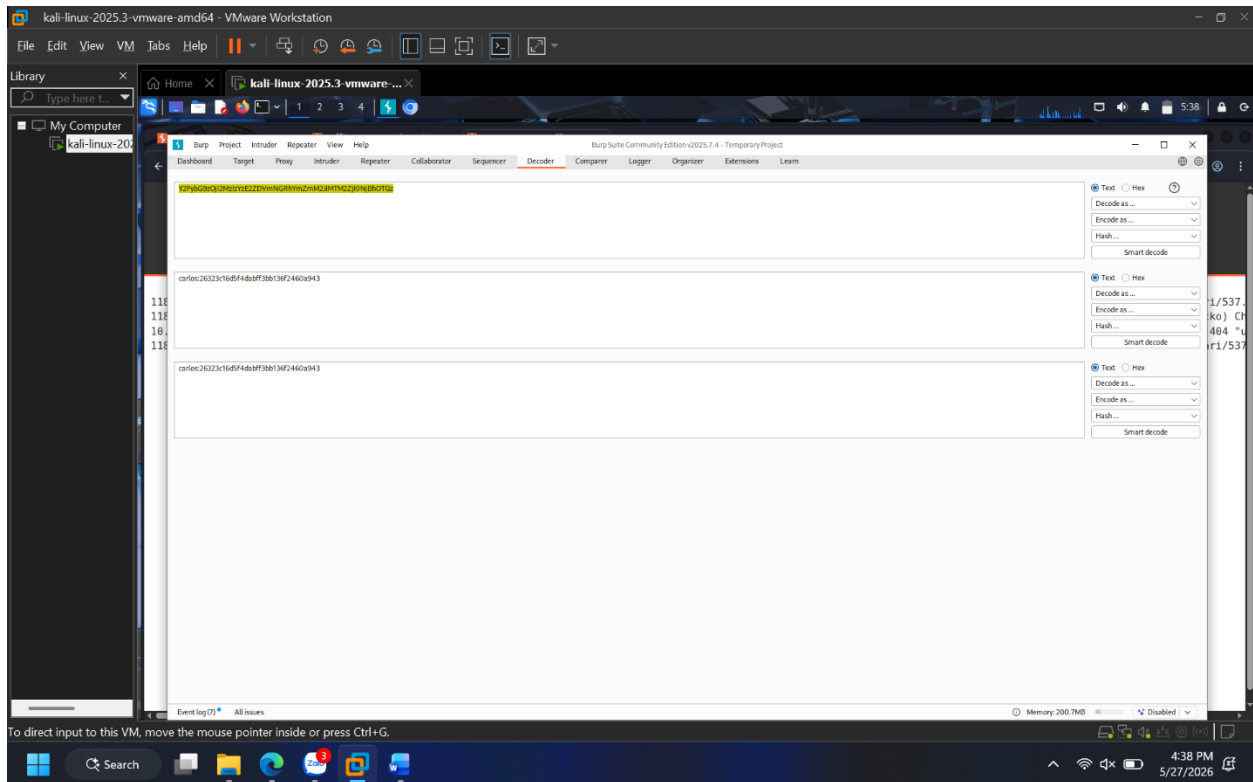


Bước 7: Copy

stay-logged-in=Y2FybG9zOjI2MzIzYzE2ZDVmNGRhYmZmM2JiMTM2ZjI0NjBhOTQz

Decode Base64:

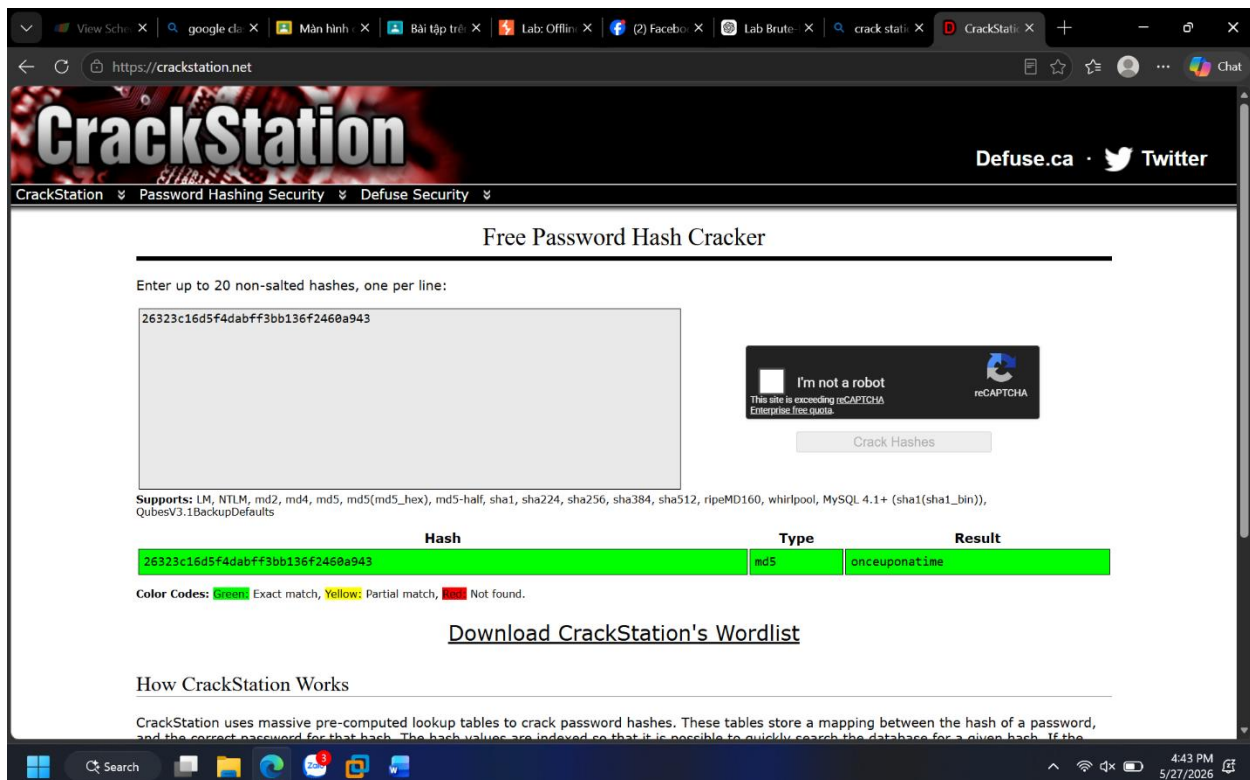
carlos:26323c16d5f4dabff3bb136f2460a943



Bước 8: Copy hash:

26323c16d5f4dabff3bb136f2460a943

Tra cứu trên công cụ tìm kiếm và xác định password là:
onceuponatime



Bước 9: Quay lại đăng nhập

Delete account là hoàn thành lab

